

Under the FedRAMP Moderate baseline, IR-2 (IR-2 Incident Response Training): FedRAMP Moderate Baseline · IR-2 · Incident Response Training Control Statement: a. Provide incident response training to system users consistent with assigned roles and responsibilities: 1. Within [organization-defined parameter] of assuming an incident response role or responsibility or acquiring system access; 2. When required by system changes; and 3. [organization-defined parameter] thereafter; and b. Review and update incident response training content [organization-defined paramet

NIST SP 800-171 Rev 3 control 03.06.04 (03.06.04 Incident Response Training) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Incident Response (IR) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Under the FedRAMP Moderate baseline, IR-8 (IR-8 Incident Response Plan): FedRAMP Moderate Baseline · IR-8 · Incident Response Plan Control Statement: a. Develop an incident response plan that: 1. Provides the organization with a roadmap for implementing its incident response capability; 2. Describes the structure and organization of the incident response capability; 3. Provides a high-level approach for how the incident response capability fits into the overall organization; 4. Meets the unique requirements of the organization, which relate to mission, size,

IR-4.8 · Correlation with External Organizations Control Statement: Coordinate with [organization-defined parameter] to correlate and share [organization-defined parameter] to achieve a cross-organization perspective on incident awareness and more effective incident responses. Supplemental Guidance: Coordinate with [organization-defined parameter] to correlate and share [organization-defined parameter] to achieve a cross-organization perspective on incident awareness and more effective incident responses. The coordination of incident information with external organizations-including mission or business partners, military or coalition partners, customers, and developers-can provide significant benefits. Cross-organizational coordination can serve as an important risk management capability. This capability allows organizations to leverage information from a variety of sources to effectively respond to incidents and breaches that could potentially affect the organization's operations, assets, and individuals.

NIST SP 800-53 Rev 5 control IR-3.3 (Continuous Improvement): IR-3.3 · Continuous Improvement Control Statement: Use qualitative and quantitative data from testing to: (a) Determine the effectiveness of incident response processes; (b) Continuously improve incident response processes; and (c) Provide incident response measures and metrics that are accurate, consistent, and in a reproducible format. Supplemental Guidance: Use qualitative and quantitative da

NIST SP 800-53 Rev 5 control IR-4.14 (Security Operations Center) is assessed by examining, interviewing, and testing: IR-4.14 · Security Operations Center Control Statement: Establish and maintain a security operations center. Supplemental Guidance: Establish and maintain a security operations center. A security operations center (SOC) is the focal point for security operations and computer network defense for an organization. The purpose of the SOC is to defend and monitor an organization's systems and networks (i.e., cyber infrastructure) on an ongoing basis. The SOC is also responsible for detecting, analy

NIST SP 800-171 Rev 3 control 03.06.01 (03.06.01 Incident Handling) requires organizations to implement the following: 03.06.01 · Incident Handling Supplemental Guidance: Incident-related information can be obtained from a variety of sources, including audit monitoring, network monitoring, physical access monitoring, user and administrator reports, and reported supply chain events. An effective incident handling capability involves coordination among many organizational entities, including mission and business owners, system owners, human resources offices, physical and personnel security offices, legal departm For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.06.01.

NIST SP 800-53 Rev 5 control IR-4.7 (Insider Threats · Intra-organization Coordination) is assessed by examining, interviewing, and testing: IR-4.7 · Insider Threats · Intra-organization Coordination Control Statement: Coordinate an incident handling capability for insider threats that includes the

following organizational entities [organization-defined parameter]. Supplemental Guidance: Coordinate an incident handling capability for insider threats that includes the following organizational entities [organization-defined parameter]. Incident handling for insider threat incidents (e.g., preparation, detection and analysis, containm

NIST SP 800-53 Rev 5 control IR-8 (Incident Response Plan) is defined as follows: IR-8 · Incident Response Plan Control Statement: a. Develop an incident response plan that: 1. Provides the organization with a roadmap for implementing its incident response capability; 2. Describes the structure and organization of the incident response capability; 3. Provides a high-level approach for how the incident response capability fits into the overall organization; 4. Meets the unique requirements of the organization, which relate to mission, size, structure, and functions; 5. Defines reportable incidents; 6. Provides metrics for measuring the incident response capabili

NIST SP 800-53 Rev 5 control IR-2.2 (Automated Training Environments) is assessed by examining, interviewing, and testing: IR-2.2 · Automated Training Environments Control Statement: Provide an incident response training environment using [organization-defined parameter]. Supplemental Guidance: Provide an incident response training environment using [organization-defined parameter]. Automated mechanisms can provide a more thorough and realistic incident response training environment. This can be accomplished, for example, by providing more complete coverage of incident response issues, selecting more realistic tra

NIST SP 800-171 Rev 3 control 03.06.04 (03.06.04 Incident Response Training) is assessed by examining the following: Assessment Objectives: - incident response training for system users consistent with assigned roles and responsibilities is provided within [organization-defined parameter] of assuming an incident response role or responsibility or acquiring system access. - incident response training for system users consistent with assigned roles and responsibilities is provided when required by system changes. - incident response training for system users consistent with assigned roles and responsibilities is provided [organization-defined parameter] thereafter. - incident response training content is updat

System-level· Control IR-1 Discussion: Change ·security or privacy incidents· to ·security incidents or breaches· Control Enhancement IR-2(1) Discussion: Delete ·Incident response training includes tabletop exercises that simulate a breach.

Incident Response 3.6.2 Incident Tracking and Reporting a. Track and document system security incidents. b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period] (03.06.02.b). c. Report incident information to [Assignment: organization-defined authorities] (03.06.02.c). d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents. Related Controls: IR-05, IR-06, IR-07 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.06.02.b [Assignment: organization-defined time period] near real time or as soon as practicable upon discovery 03.06.02.c [Assignment: organization-defined authorities] all applicable personnel and entities as specified by the contract, and in accordance with any incident response plan notification procedures Incident Response 3.6.3 Incident Response Testing Test the effectiveness of the incident response capability [Assignment: organization-defined frequency] (03.06.03). Related Controls: IR-03 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.06.03 [Assignment: organization-defined frequency] at least every 12 months

Under the FedRAMP High baseline, IR-3 (IR-3 Incident Response Testing): FedRAMP High Baseline · IR-3 · Incident Response Testing Control Statement: Test the effectiveness of the incident response capability for the system [organization-defined parameter] using the following tests: [organization-defined parameter]. Supplemental Guidance: Test the effectiveness of the incident response capability for the system [organization-defined parameter] using the following tests: [organization-defined parameter]. Organizations test incident response capabilities to determine

NIST SP 800-53 Rev 5 control IR-2.1 (Simulated Events) summarizes the requirements for this control: IR-2.1 · Simulated Events Control Statement: Incorporate simulated events into incident response training to facilitate the required response by personnel in crisis situations. Supplemental Guidance: Incorporate simulated events into incident response training to facilitate the required response by personnel in crisis situations. Organizations establish requirements for responding to

incidents in incident response plans. Incorporating simulated events into incident response training helps to e

NIST SP 800-53 Rev 5 control IR-3.2 (Coordination with Related Plans): IR-3.2 · Coordination with Related Plans Control Statement: Coordinate incident response testing with organizational elements responsible for related plans. Supplemental Guidance: Coordinate incident response testing with organizational elements responsible for related plans. Organizational plans related to incident response testing include business continuity plans, disaster recovery plans, con

Under the FedRAMP High baseline, IR-8 (IR-8 Incident Response Plan): FedRAMP High Baseline · IR-8 · Incident Response Plan Control Statement: a. Develop an incident response plan that: 1. Provides the organization with a roadmap for implementing its incident response capability; 2. Describes the structure and organization of the incident response capability; 3. Provides a high-level approach for how the incident response capability fits into the overall organization; 4. Meets the unique requirements of the organization, which relate to mission, size, str

NIST SP 800-171 Rev 3 control 03.06.04 (03.06.04 Incident Response Training) is assessed by examining the following: Assessment Objectives: - incident response training for system users consistent with assigned roles and responsibilities is provided within [organization-defined parameter] of assuming an incident response role or responsibility or acquiring system access. - incident response training for system users consistent with assigned roles and responsibilities is provided when required by system changes. - incident response training for system users consistent with assigned roles and responsibilities is provided [organization-defined parameter] thereafter. - incident response training content is updat

Under the FedRAMP High baseline, IR-5 (IR-5 Incident Monitoring): FedRAMP High Baseline · IR-5 · Incident Monitoring Control Statement: Track and document incidents. Supplemental Guidance: Track and document incidents. Documenting incidents includes maintaining records about each incident, the status of the incident, and other pertinent information necessary for forensics as well as evaluating incident details, trends, and handling. Incident information can be obtained from a variety of sources, including network monitoring, incident reports, incident respon

NIST SP 800-53 Rev 5 control IR-9.4 (Exposure to Unauthorized Personnel): IR-9.4 · Exposure to Unauthorized Personnel Control Statement: Employ the following controls for personnel exposed to information not within assigned access authorizations: [organization-defined parameter]. Supplemental Guidance: Employ the following controls for personnel exposed to information not within assigned access authorizations: [organization-defined parameter]. Controls include ensurin

NIST SP 800-171 Rev 3 control 03.06.03 (03.06.03 Incident Response Testing) is assessed by examining the following: Assessment Objectives: - the effectiveness of the incident response capability is tested [organization-defined parameter].

NIST SP 800-171 Rev 3 control 03.06.05 (03.06.05 Incident Response Plan) is assessed by examining the following: Assessment Objectives: - an incident response plan is developed that provides the organization with a roadmap for implementing its incident response capability. - an incident response plan is developed that describes the structure and organization of the incident response capability. - an incident response plan is developed that provides a high-level approach for how the incident response capability fits into the overall organization. - an incident response plan is developed that defines reportable incidents. - an incident response plan is developed that addresses the sharing of incident infor

From the NIST SP 800-172 Rev 3 Final Public Draft: This requirement enhances SP 800-171 requirement 03.06.02. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 PROTECTION STRATEGY 1267 P RA, DLO ADVERSARY EFFECTS Expose (Detect, Reveal) REFERENCES Source Control: IR-05(01) 3.7. Maintenance 03.0 7.01E Software Updates and Patches for Maintenance Tools Inspect maintenance tools to ensure the latest software updates and patches are installed. DISCUSSION Maintenance tools using outdated and/or unpatched software can provide a threat vector for adversaries and result in a significant vulnerability for organizations. This requirement enhances SP 800-171 requirement 03.07.04. PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt) REFERENCES Source Control: MA-

NIST SP 800-171 Rev 3 control 03.06.04 (03.06.04 Incident Response Training) falls under the Incident Response family. Control Statement: SR-03.06.04.a Provide incident response training to system users consistent with assigned roles and responsibilities: SR-03.06.04.a.01 Within [organization-defined parameter] of assuming an incident response role or responsibility or acquiring system access, SR-03.06.04.a.02 When required by system changes, and SR-03.06.04.a.03 [organization-defined parameter] thereafter. SR-03.06.04.b Review and update incident response training content [organization-defined parameter] and following [organization-defined parameter]. Supplemental Guidance: Incident response training is associated with the assigned roles and responsibilities of organizational personnel to ensure that the appropriate content and level of detail are included in such training. For example, users may only need to know how to recognize an incident or whom to call; system administrators may require additional training on how to handle incidents; and incident responders may receive specific training on data collection techniques, forensics, reportin

NIST SP 800-53 Rev 5 control IR-4.4 (Information Correlation) summarizes the requirements for this control: IR-4.4 · Information Correlation Control Statement: Correlate incident information and individual incident responses to achieve an organization-wide perspective on incident awareness and response. Supplemental Guidance: Correlate incident information and individual incident responses to achieve an organization-wide perspective on incident awareness and response. Sometimes, a threat event, such as a hostile cyber-attack, can only be observed by bringing together information from different sourc

Under the FedRAMP High baseline, IR-4.1 (IR-4.1 Automated Incident Handling Processes): FedRAMP High Baseline · IR-4.1 · Automated Incident Handling Processes Control Statement: Support the incident handling process using [organization-defined parameter]. Supplemental Guidance: Support the incident handling process using [organization-defined parameter]. Automated mechanisms that support incident handling processes include online incident management systems and tools that support the collection of live response data, full network packet capture, and forensic analysis. Assessment

NIST SP 800-53 Rev 5 control IR-4.12 (Malicious Code and Forensic Analysis) summarizes the requirements for this control: IR-4.12 · Malicious Code and Forensic Analysis Control Statement: Analyze malicious code and/or other residual artifacts remaining in the system after the incident. Supplemental Guidance: Analyze malicious code and/or other residual artifacts remaining in the system after the incident. When conducted carefully in an isolated environment, analysis of malicious code and other residual artifacts of a security incident or breach can give the organization insight into adversary tactics, techniques,

NIST SP 800-53 Rev 5 control IR-7.1 (Automation Support for Availability of Information and Support) is assessed by examining, interviewing, and testing: IR-7.1 · Automation Support for Availability of Information and Support Control Statement: Increase the availability of incident response information and support using [organization-defined parameter]. Supplemental Guidance: Increase the availability of incident response information and support using [organization-defined parameter]. Automated mechanisms can provide a push or pull capability for users to obtain incident response assistance. For example, individuals may have access to a website

NIST SP 800-171 Rev 3 control 03.06.03 (03.06.03 Incident Response Testing) falls under the Incident Response family. 03.06.03 · Incident Response Testing Supplemental Guidance: Organizations test incident response capabilities to determine their effectiveness and identify potential weaknesses or deficiencies. Incident response testing includes the use of checklists, walk-through or tabletop exercises, and simulations. Incident response testing can include a determination of the effects of incident response on organizational operations, organizational assets, and individuals. Qualitative and quantitative data Supplemental Guidance: Organizations test incident response capabilities to determine their effectiveness and identify potential weaknesses or deficiencies. Incident response testing includes the use of checklists, walk-through or tabletop exercises, and simulations. Incident response testing can include a determination of the effects of incident response on organizational operations, organizational assets, and individuals. Qualitative and quantitative data can help determine the effectiveness o

Under the FedRAMP High baseline, IR-6 (IR-6 Incident Reporting): FedRAMP High Baseline · IR-6 · Incident Reporting Control Statement: a. Require personnel to report suspected incidents to the organizational incident response capability within [organization-defined parameter] ; and b. Report incident information to [organization-defined parameter]. Supplemental Guidance: a. Require personnel to report suspected incidents to the organizational incident response capability within [organization-defined parameter] ; and b. Report incident information to [organiz

NIST SP 800-171 Rev 3 control 03.06.01 (03.06.01 Incident Handling) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Incident Response (IR) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control IR-5.1 (Automated Tracking, Data Collection, and Analysis) summarizes the requirements for this control: IR-5.1 · Automated Tracking, Data Collection, and Analysis Control Statement: Track incidents and collect and analyze incident information using [organization-defined parameter]. Supplemental Guidance: Track incidents and collect and analyze incident information using [organization-defined parameter]. Automated mechanisms for tracking incidents and collecting and analyzing incident information include Computer Incident Response Centers or other electronic databases of incidents and network mon

Under the FedRAMP Moderate baseline, IR-7 (IR-7 Incident Response Assistance): FedRAMP Moderate Baseline · IR-7 · Incident Response Assistance Control Statement: Provide an incident response support resource, integral to the organizational incident response capability, that offers advice and assistance to users of the system for the handling and reporting of incidents. Supplemental Guidance: Provide an incident response support resource, integral to the organizational incident response capability, that offers advice and assistance to users of the system for the handling

NIST SP 800-53 Rev 5 control IR-4.11 (Integrated Incident Response Team) is assessed by examining, interviewing, and testing: IR-4.11 · Integrated Incident Response Team Control Statement: Establish and maintain an integrated incident response team that can be deployed to any location identified by the organization in [organization-defined parameter]. Supplemental Guidance: Establish and maintain an integrated incident response team that can be deployed to any location identified by the organization in [organization-defined parameter]. An integrated incident response team is a team of experts that assesses, documents

Control IR-4: in information exchange agreements and their obligations for reporting incidents to government oversight bodies (e.g., Federal Acquisition Security Council). Related Controls: CA-3, MA-2, SA-9, SR-8. (11) INCIDENT HANDLING | INTEGRATED INCIDENT RESPONSE TEAM Establish and maintain an integrated incident response team that can be deployed to any location identified by the organization in [Assignment: organization-defined time period]. CHAPTER THREE PAGE 154 T h s i p u b l i c a t i o n i s a v a i l a b l e f r e e o f c h a r g e f r o m : <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

Discussion: An integrated incident response team is a team of experts that assesses, documents, and responds to incidents so that organizational systems and networks can recover quickly and implement the necessary controls to avoid future incidents. Incident response team personnel include forensic and malicious code analysts, tool developers, systems security and privacy engineers, and real-time operations personnel. The incident handling capability includes performing rapid forensic preservation of evidence and analysis of and response to intrusions. For some organizations, the incident response team can be a cross-organizational entity. An integrated incident response team facilitates information sharing and allows organizational personnel (e.g., developers, implementers, and operators) to leverage team knowledge of the threat and implement defensive measures that enable organizations to deter intrusions more effectively.

NIST SP 800-171 Rev 3 control 03.06.05 (03.06.05 Incident Response Plan) is assessed by examining the following: Assessment Objectives: - an incident response plan is developed that provides the organization with a roadmap for implementing its incident response capability. - an incident response plan is developed that describes the structure and organization of the incident response

capability. - an incident response plan is developed that provides a high-level approach for how the incident response capability fits into the overall organization. - an incident response plan is developed that defines reportable incidents. - an incident response plan is developed that addresses the sharing of incident information

Under the FedRAMP High baseline, IR-3.2 (IR-3.2 Coordination with Related Plans): FedRAMP High Baseline · IR-3.2 · Coordination with Related Plans Control Statement: Coordinate incident response testing with organizational elements responsible for related plans. Supplemental Guidance: Coordinate incident response testing with organizational elements responsible for related plans. Organizational plans related to incident response testing include business continuity plans, disaster recovery plans, continuity of operations plans, contingency plans, crisis communications plans,

Under the FedRAMP Moderate baseline, IR-9.3 (IR-9.3 Post-spill Operations): FedRAMP Moderate Baseline · IR-9.3 · Post-spill Operations Control Statement: Implement the following procedures to ensure that organizational personnel impacted by information spills can continue to carry out assigned tasks while contaminated systems are undergoing corrective actions: [organization-defined parameter]. Supplemental Guidance: Implement the following procedures to ensure that organizational personnel impacted by information spills can continue to carry out assigned tasks while c

NIST SP 800-53 Rev 5 control IR-7.2 (Coordination with External Providers) is assessed by examining, interviewing, and testing: IR-7.2 · Coordination with External Providers Control Statement: (a) Establish a direct, cooperative relationship between its incident response capability and external providers of system protection capability; and (b) Identify organizational incident response team members to the external providers. Supplemental Guidance: (a) Establish a direct, cooperative relationship between its incident response capability and external providers of system protection capability; and (b) Identify organization

NIST SP 800-53 Rev 5 control IR-3.3 (Continuous Improvement) summarizes the requirements for this control: IR-3.3 · Continuous Improvement Control Statement: Use qualitative and quantitative data from testing to: (a) Determine the effectiveness of incident response processes; (b) Continuously improve incident response processes; and (c) Provide incident response measures and metrics that are accurate, consistent, and in a reproducible format. Supplemental Guidance: Use qualitative and quantitative data from testing to: (a) Determine the effectiveness of incident response processes; (b) Continuously

Under the FedRAMP Moderate baseline, IR-6.3 (IR-6.3 Supply Chain Coordination): FedRAMP Moderate Baseline · IR-6.3 · Supply Chain Coordination Control Statement: Provide incident information to the provider of the product or service and other organizations involved in the supply chain or supply chain governance for systems or system components related to the incident. Supplemental Guidance: Provide incident information to the provider of the product or service and other organizations involved in the supply chain or supply chain governance for systems or system components

NIST SP 800-53 Rev 5 control IR-2.3 (Breach): IR-2.3 · Breach Control Statement: Provide incident response training on how to identify and respond to a breach, including the organization's process for reporting a breach. Supplemental Guidance: Provide incident response training on how to identify and respond to a breach, including the organization's process for reporting a breach. For federal agencies, an incident that involves personally i

NIST SP 800-53 Rev 5 control IR-3.2 (Coordination with Related Plans) is defined as follows: IR-3.2 · Coordination with Related Plans Control Statement: Coordinate incident response testing with organizational elements responsible for related plans. Supplemental Guidance: Coordinate incident response testing with organizational elements responsible for related plans. Organizational plans related to incident response testing include business continuity plans, disaster recovery plans, continuity of operations plans, contingency plans, crisis communications plans, critical infrastructure plans, and occupant emergency plans.

NIST SP 800-53 Rev 5 control IR-2.3 (Breach) is assessed by examining, interviewing, and testing: IR-2.3 · Breach Control Statement: Provide incident response training on how to identify and

respond to a breach, including the organization's process for reporting a breach. Supplemental Guidance: Provide incident response training on how to identify and respond to a breach, including the organization's process for reporting a breach. For federal agencies, an incident that involves personally identifiable information is considered a breach. A breach results in the loss of control, compromise,

NIST SP 800-53 Rev 5 control IR-4.11 (Integrated Incident Response Team) summarizes the requirements for this control: IR-4.11 · Integrated Incident Response Team Control Statement: Establish and maintain an integrated incident response team that can be deployed to any location identified by the organization in [organization-defined parameter]. Supplemental Guidance: Establish and maintain an integrated incident response team that can be deployed to any location identified by the organization in [organization-defined parameter]. An integrated incident response team is a team of experts that assesses, documents

NIST SP 800-53 Rev 5 control IR-9.4 (Exposure to Unauthorized Personnel) is assessed by examining, interviewing, and testing: IR-9.4 · Exposure to Unauthorized Personnel Control Statement: Employ the following controls for personnel exposed to information not within assigned access authorizations: [organization-defined parameter]. Supplemental Guidance: Employ the following controls for personnel exposed to information not within assigned access authorizations: [organization-defined parameter]. Controls include ensuring that personnel who are exposed to spilled information are made aware of the laws, executive orders

NIST SP 800-53 Rev 5 control IR-4.5 (Automatic Disabling of System) summarizes the requirements for this control: IR-4.5 · Automatic Disabling of System Control Statement: Implement a configurable capability to automatically disable the system if [organization-defined parameter] are detected. Supplemental Guidance: Implement a configurable capability to automatically disable the system if [organization-defined parameter] are detected. Organizations consider whether the capability to automatically disable the system conflicts with continuity of operations requirements specified as part of [CP-2](#cp-2) or

NIST SP 800-53 Rev 5 control IR-2.1 (Simulated Events) is defined as follows: IR-2.1 · Simulated Events Control Statement: Incorporate simulated events into incident response training to facilitate the required response by personnel in crisis situations. Supplemental Guidance: Incorporate simulated events into incident response training to facilitate the required response by personnel in crisis situations. Organizations establish requirements for responding to incidents in incident response plans. Incorporating simulated events into incident response training helps to ensure that personnel understand their individual responsibilities and what specific actions to take

NIST SP 800-53 Rev 5 control IR-4.3 (Continuity of Operations) is assessed by examining, interviewing, and testing: IR-4.3 · Continuity of Operations Control Statement: Identify [organization-defined parameter] and take the following actions in response to those incidents to ensure continuation of organizational mission and business functions: [organization-defined parameter]. Supplemental Guidance: Identify [organization-defined parameter] and take the following actions in response to those incidents to ensure continuation of organizational mission and business functions: [organization-defined parameter].

Implementing 03.06.02 (03.06.02 Incident Monitoring, Reporting, and Response Assistance) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.06.02 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.06.02 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

Under the FedRAMP Low baseline, IR-6 (IR-6 Incident Reporting): FedRAMP Low Baseline · IR-6 ·

Incident Reporting Control Statement: a. Require personnel to report suspected incidents to the organizational incident response capability within [organization-defined parameter] ; and b. Report incident information to [organization-defined parameter]. Supplemental Guidance: a. Require personnel to report suspected incidents to the organizational incident response capability within [organization-defined parameter] ; and b. Report incident information to [organiza

NIST SP 800-53 Rev 5 control IR-3 (Incident Response Testing) is assessed by examining, interviewing, and testing: IR-3 · Incident Response Testing Control Statement: Test the effectiveness of the incident response capability for the system [organization-defined parameter] using the following tests: [organization-defined parameter]. Supplemental Guidance: Test the effectiveness of the incident response capability for the system [organization-defined parameter] using the following tests: [organization-defined parameter]. Organizations test incident response capabilities to determine their effectiveness and

NIST SP 800-171 Rev 3 control 03.06.01 (03.06.01 Incident Handling) is assessed by examining the following: Assessment Objectives: - an incident-handling capability that is consistent with the incident response plan is implemented. - the incident handling capability includes preparation. - the incident handling capability includes detection and analysis. - the incident handling capability includes containment. - the incident handling capability includes eradication. - the incident handling capability includes recovery.

Under the FedRAMP Low baseline, IR-7 (IR-7 Incident Response Assistance): FedRAMP Low Baseline · IR-7 · Incident Response Assistance Control Statement: Provide an incident response support resource, integral to the organizational incident response capability, that offers advice and assistance to users of the system for the handling and reporting of incidents. Supplemental Guidance: Provide an incident response support resource, integral to the organizational incident response capability, that offers advice and assistance to users of the system for the handling and r

NIST SP 800-53 Rev 5 control IR-4.6 (Insider Threats): IR-4.6 · Insider Threats Control Statement: Implement an incident handling capability for incidents involving insider threats. Supplemental Guidance: Implement an incident handling capability for incidents involving insider threats. Explicit focus on handling incidents involving insider threats provides additional emphasis on this type of threat and the need for specific incident handling capabi

NIST SP 800-53 Rev 5 control IR-6.2 (Vulnerabilities Related to Incidents) summarizes the requirements for this control: IR-6.2 · Vulnerabilities Related to Incidents Control Statement: Report system vulnerabilities associated with reported incidents to [organization-defined parameter]. Supplemental Guidance: Report system vulnerabilities associated with reported incidents to [organization-defined parameter]. Reported incidents that uncover system vulnerabilities are analyzed by organizational personnel including system owners, mission and business owners, senior agency information security officers, senior agen

Under the FedRAMP High baseline, IR-9.3 (IR-9.3 Post-spill Operations): FedRAMP High Baseline · IR-9.3 · Post-spill Operations Control Statement: Implement the following procedures to ensure that organizational personnel impacted by information spills can continue to carry out assigned tasks while contaminated systems are undergoing corrective actions: [organization-defined parameter]. Supplemental Guidance: Implement the following procedures to ensure that organizational personnel impacted by information spills can continue to carry out assigned tasks while conta

NIST SP 800-171 Rev 3 control 03.06.03 (03.06.03 Incident Response Testing) is assessed by examining the following: Assessment Objectives: - the effectiveness of the incident response capability is tested [organization-defined parameter].

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Incident Response 3.6.2 Incident Tracking and Reporting a. Track and document system security incidents. b. Report suspected incidents to the organizational incident response capability within [Assignment: organization-defined time period] (03.06.02.b). c. Report incident information to [Assignment: organization-defined authorities] (03.06.02.c). d. Provide an incident response support resource that offers advice and assistance to system users on handling and reporting incidents. Related Controls: IR-05, IR-06, IR-07 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.06.02.b

[Assignment: organization-defined time period] near real time or as soon as practicable upon discovery 03.06.02.c [Assignment: organization-defined authorities] all applicable personnel and

NIST SP 800-171 Rev 3 control 03.06.02 (03.06.02 Incident Monitoring, Reporting, and Response Assistance) is assessed by examining the following: Assessment Objectives: - system security incidents are tracked. - system security incidents are documented. - suspected incidents are reported to the organizational incident response capability within [organization-defined parameter]. - incident information is reported to [organization-defined parameter]. - an incident response support resource that offers advice and assistance to system users on handling and reporting incidents is provided.

Under the FedRAMP High baseline, IR-2.1 (IR-2.1 Simulated Events): FedRAMP High Baseline · IR-2.1 · Simulated Events Control Statement: Incorporate simulated events into incident response training to facilitate the required response by personnel in crisis situations. Supplemental Guidance: Incorporate simulated events into incident response training to facilitate the required response by personnel in crisis situations. Organizations establish requirements for responding to incidents in incident response plans. Incorporating simulated events into incident resp

NIST SP 800-53 Rev 5 control IR-6.3 (Supply Chain Coordination) summarizes the requirements for this control: IR-6.3 · Supply Chain Coordination Control Statement: Provide incident information to the provider of the product or service and other organizations involved in the supply chain or supply chain governance for systems or system components related to the incident. Supplemental Guidance: Provide incident information to the provider of the product or service and other organizations involved in the supply chain or supply chain governance for systems or system components related to the incident. Org

NIST SP 800-53 Rev 5 control IR-4.13 (Behavior Analysis) is assessed by examining, interviewing, and testing: IR-4.13 · Behavior Analysis Control Statement: Analyze anomalous or suspected adversarial behavior in or related to [organization-defined parameter]. Supplemental Guidance: Analyze anomalous or suspected adversarial behavior in or related to [organization-defined parameter]. If the organization maintains a deception environment, an analysis of behaviors in that environment, including resources targeted by the adversary and timing of the incident or event, can provide insight into adversarial t

NIST SP 800-53 Rev 5 control IR-3.1 (Automated Testing) is assessed by examining, interviewing, and testing: IR-3.1 · Automated Testing Control Statement: Test the incident response capability using [organization-defined parameter]. Supplemental Guidance: Test the incident response capability using [organization-defined parameter]. Organizations use automated mechanisms to more thoroughly and effectively test incident response capabilities. This can be accomplished by providing more complete coverage of incident response issues, selecting realistic test scenarios and environments, and stressing the r

03.06.03 · Incident Response Testing Supplemental Guidance: Organizations test incident response capabilities to determine their effectiveness and identify potential weaknesses or deficiencies. Incident response testing includes the use of checklists, walk-through or tabletop exercises, and simulations. Incident response testing can include a determination of the effects of incident response on organizational operations, organizational assets, and individuals. Qualitative and quantitative data can help determine the effectiveness of incident response processes. Assessment Objectives: - the effectiveness of the incident response capability is tested [organization-defined parameter]. Organization-Defined Parameters: - A.03.06.03.ODP.01: frequency

FedRAMP High Baseline · IR-9.2 · Training Control Statement: Provide information spillage response training [organization-defined parameter]. Supplemental Guidance: Provide information spillage response training [organization-defined parameter]. Organizations establish requirements for responding to information spillage incidents in incident response plans. Incident response training on a regular basis helps to ensure that organizational personnel understand their individual responsibilities and what specific actions to take when spillage incidents occur. Assessment Objectives: Provide information spillage response training [organization-defined parameter]. FedRAMP Parameter Values: ir-09.02_odp: at least annually

Under the FedRAMP Moderate baseline, IR-3.2 (IR-3.2 Coordination with Related Plans): FedRAMP Moderate Baseline · IR-3.2 · Coordination with Related Plans Control Statement: Coordinate incident response testing with organizational elements responsible for related plans. Supplemental Guidance: Coordinate incident response testing with organizational elements responsible for related plans. Organizational plans related to incident response testing include business continuity plans, disaster recovery plans, continuity of operations plans, contingency plans, crisis communications pl

and incident responders may receive more specific training on forensics, data collection techniques, reporting, system recovery, and system restoration. Incident response training includes user training in identifying and reporting suspicious activities from external and internal sources. Incident response training for users may be provided as part of AT-2 or AT-3. Events that may precipitate an update to incident response training content include, but are not limited to, incident response plan testing or response to an actual incident (lessons learned), assessment or audit findings, or changes in applicable laws, executive orders, directives, regulations, policies, standards, and guidelines. Related Controls: AT-2, AT-3, AT-4, CP-3, IR-3, IR-4, IR-8, IR-9. Control Enhancements: (1) INCIDENT RESPONSE TRAINING | SIMULATED EVENTS Incorporate simulated events into incident response training to facilitate the required response by personnel in crisis situations.

Under the FedRAMP High baseline, IR-7 (IR-7 Incident Response Assistance): FedRAMP High Baseline · IR-7 · Incident Response Assistance Control Statement: Provide an incident response support resource, integral to the organizational incident response capability, that offers advice and assistance to users of the system for the handling and reporting of incidents. Supplemental Guidance: Provide an incident response support resource, integral to the organizational incident response capability, that offers advice and assistance to users of the system for the handling and

Under the FedRAMP High baseline, IR-4 (IR-4 Incident Handling): FedRAMP High Baseline · IR-4 · Incident Handling Control Statement: a. Implement an incident handling capability for incidents that is consistent with the incident response plan and includes preparation, detection and analysis, containment, eradication, and recovery; b. Coordinate incident handling activities with contingency planning activities; c. Incorporate lessons learned from ongoing incident handling activities into incident response procedures, training, and testing, and implement the r

Under the FedRAMP High baseline, IR-4.11 (IR-4.11 Integrated Incident Response Team): FedRAMP High Baseline · IR-4.11 · Integrated Incident Response Team Control Statement: Establish and maintain an integrated incident response team that can be deployed to any location identified by the organization in [organization-defined parameter]. Supplemental Guidance: Establish and maintain an integrated incident response team that can be deployed to any location identified by the organization in [organization-defined parameter]. An integrated incident response team is a team of experts

NIST SP 800-53 Rev 5 control IR-6.3 (Supply Chain Coordination): IR-6.3 · Supply Chain Coordination Control Statement: Provide incident information to the provider of the product or service and other organizations involved in the supply chain or supply chain governance for systems or system components related to the incident. Supplemental Guidance: Provide incident information to the provider of the product or service and other organizations involved in the s

Under the FedRAMP Low baseline, IR-5 (IR-5 Incident Monitoring): FedRAMP Low Baseline · IR-5 · Incident Monitoring Control Statement: Track and document incidents. Supplemental Guidance: Track and document incidents. Documenting incidents includes maintaining records about each incident, the status of the incident, and other pertinent information necessary for forensics as well as evaluating incident details, trends, and handling. Incident information can be obtained from a variety of sources, including network monitoring, incident reports, incident respons

From the NIST SP 800-172 Rev 3 Final Public Draft: This requirement 1201 enhances SP 800-171 requirement 03.06.01. PROTECTION STRATEGY DLO ADVERSARY EFFECTS Limit (Shorten, Reduce); Expose (Detect, Reveal) REFERENCES Source Control: IR-04(14) 03.0 6.02E Integrated Incident Response Team Establish and maintain an integrated incident response team that can be deployed to any location identified by the organization in [Assignment: organization-defined time period]. DISCUSSION An integrated incident response team is a group of individuals who assess, document, and respond to incidents so that organizational systems and networks can recover quickly and

implement the necessary controls to avoid future incidents. Incident response team personnel include forensic and malicious code analysts, tool developers, systems security eng

Control IR-1: specific policies and procedures. The policy can be included as part of the general security and privacy policy or be represented by multiple policies that reflect the complex nature of organizations. Procedures can be established for security and privacy programs, for mission or business processes, and for systems, if needed. Procedures describe how the policies or controls are implemented and can be directed at the individual or role that is the object of the procedure. Procedures can be documented in system security and privacy plans or in one or more separate documents. Events that may precipitate an update to incident response policy and procedures include assessment or audit findings, security incidents or breaches, or changes in laws, executive orders, directives, regulations, policies, standards, and guidelines. Simply restating controls does not constitute an organizational policy or procedure. Related Controls: PM-9, PS-8, SI-12. Control Enhancements: None. References: [OMB A-130], [SP 800-12], [SP 800-30], [SP 800-39], [SP 800-50], [SP 800-61], [SP 800-83], [SP 800-100]. CHAPTER THREE PAGE 149 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53.r5>. NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

IR-3.2 · Coordination with Related Plans Control Statement: Coordinate incident response testing with organizational elements responsible for related plans. Supplemental Guidance: Coordinate incident response testing with organizational elements responsible for related plans. Organizational plans related to incident response testing include business continuity plans, disaster recovery plans, continuity of operations plans, contingency plans, crisis communications plans, critical infrastructure plans, and occupant emergency plans.

Under the FedRAMP High baseline, IR-1 (IR-1 Policy and Procedures): FedRAMP High Baseline · IR-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] incident response policy that: 2. Procedures to facilitate the implementation of the incident response policy and the associated incident response controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the incident response policy and procedure

NIST SP 800-171 Rev 3 control 03.06.02 (03.06.02 Incident Monitoring, Reporting, and Response Assistance) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Incident Response (IR) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control IR-9.4 (Exposure to Unauthorized Personnel) summarizes the requirements for this control: IR-9.4 · Exposure to Unauthorized Personnel Control Statement: Employ the following controls for personnel exposed to information not within assigned access authorizations: [organization-defined parameter]. Supplemental Guidance: Employ the following controls for personnel exposed to information not within assigned access authorizations: [organization-defined parameter]. Controls include ensuring that personnel who are exposed to spilled information are made aware of the laws, executive orders

NIST SP 800-53 Rev 5 control IR-9.2 (Training) is defined as follows: IR-9.2 · Training Control Statement: Provide information spillage response training [organization-defined parameter]. Supplemental Guidance: Provide information spillage response training [organization-defined parameter]. Organizations establish requirements for responding to information spillage incidents in incident response plans. Incident response training on a regular basis helps to ensure that organizational personnel understand their individual responsibilities and what specific actions to take when spillage incidents occur.

NIST SP 800-171 Rev 3 control 03.06.05 (03.06.05 Incident Response Plan) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Incident Response (IR) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and

avoid duplicate effort.

IR-2.1 · Simulated Events Control Statement: Incorporate simulated events into incident response training to facilitate the required response by personnel in crisis situations. Supplemental Guidance: Incorporate simulated events into incident response training to facilitate the required response by personnel in crisis situations. Organizations establish requirements for responding to incidents in incident response plans. Incorporating simulated events into incident response training helps to ensure that personnel understand their individual responsibilities and what specific actions to take in crisis situations.

NIST SP 800-53 Rev 5 control IR-2 (Incident Response Training) is assessed by examining, interviewing, and testing: IR-2 · Incident Response Training Control Statement: a. Provide incident response training to system users consistent with assigned roles and responsibilities: 1. Within [organization-defined parameter] of assuming an incident response role or responsibility or acquiring system access; 2. When required by system changes; and 3. [organization-defined parameter] thereafter; and b. Review and update incident response training content [organization-defined parameter] and following [organization-defined parameter]

NIST SP 800-53 Rev 5 control IR-3.2 (Coordination with Related Plans) is assessed by examining, interviewing, and testing: IR-3.2 · Coordination with Related Plans Control Statement: Coordinate incident response testing with organizational elements responsible for related plans. Supplemental Guidance: Coordinate incident response testing with organizational elements responsible for related plans. Organizational plans related to incident response testing include business continuity plans, disaster recovery plans, continuity of operations plans, contingency plans, crisis communications plans, critical infrastructure

NIST SP 800-53 Rev 5 control IR-4.12 (Malicious Code and Forensic Analysis): IR-4.12 · Malicious Code and Forensic Analysis Control Statement: Analyze malicious code and/or other residual artifacts remaining in the system after the incident. Supplemental Guidance: Analyze malicious code and/or other residual artifacts remaining in the system after the incident. When conducted carefully in an isolated environment, analysis of malicious code and other residual artifacts of

Control IR-10: INTEGRATED INFORMATION SECURITY ANALYSIS TEAM [Withdrawn: Moved to IR-4(11).] This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. CHAPTER THREE PAGE 161 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

3.9 MAINTENANCE Quick link to Maintenance Summary Table

Under the FedRAMP High baseline, IR-7.1 (IR-7.1 Automation Support for Availability of Information and Support): FedRAMP High Baseline · IR-7.1 · Automation Support for Availability of Information and Support Control Statement: Increase the availability of incident response information and support using [organization-defined parameter]. Supplemental Guidance: Increase the availability of incident response information and support using [organization-defined parameter]. Automated mechanisms can provide a push or pull capability for users to obtain incident response assistance. For example, individuals may

NIST SP 800-53 Rev 5 control IR-2 (Incident Response Training) is defined as follows: IR-2 · Incident Response Training Control Statement: a. Provide incident response training to system users consistent with assigned roles and responsibilities: 1. Within [organization-defined parameter] of assuming an incident response role or responsibility or acquiring system access; 2. When required by system changes; and 3. [organization-defined parameter] thereafter; and b. Review and update incident response training content [organization-defined parameter] and following [organization-defined parameter]. Supplemental Guidance: a. Provide incident response training to system users

NIST SP 800-53 Rev 5 control IR-4.7 (Insider Threats · Intra-organization Coordination) summarizes the requirements for this control: IR-4.7 · Insider Threats · Intra-organization Coordination Control Statement: Coordinate an incident handling capability for insider threats that includes the

following organizational entities [organization-defined parameter]. Supplemental Guidance: Coordinate an incident handling capability for insider threats that includes the following organizational entities [organization-defined parameter]. Incident handling for insider threat incidents (e.g., preparation, detection and analysis, containm

NIST SP 800-53 Rev 5 control IR-6.2 (Vulnerabilities Related to Incidents) is assessed by examining, interviewing, and testing: IR-6.2 · Vulnerabilities Related to Incidents Control Statement: Report system vulnerabilities associated with reported incidents to [organization-defined parameter]. Supplemental Guidance: Report system vulnerabilities associated with reported incidents to [organization-defined parameter]. Reported incidents that uncover system vulnerabilities are analyzed by organizational personnel including system owners, mission and business owners, senior agency information security officers, senior agen

Under the FedRAMP Moderate baseline, IR-9.4 (IR-9.4 Exposure to Unauthorized Personnel): FedRAMP Moderate Baseline · IR-9.4 · Exposure to Unauthorized Personnel Control Statement: Employ the following controls for personnel exposed to information not within assigned access authorizations: [organization-defined parameter]. Supplemental Guidance: Employ the following controls for personnel exposed to information not within assigned access authorizations: [organization-defined parameter]. Controls include ensuring that personnel who are exposed to spilled information are made aware o

Under the FedRAMP Moderate baseline, IR-9 (IR-9 Information Spillage Response): FedRAMP Moderate Baseline · IR-9 · Information Spillage Response Control Statement: Respond to information spills by: a. Assigning [organization-defined parameter] with responsibility for responding to information spills; b. Identifying the specific information involved in the system contamination; c. Alerting [organization-defined parameter] of the information spill using a method of communication not associated with the spill; d. Isolating the contaminated system or system component; e. Eradi

Under the FedRAMP Low baseline, IR-4 (IR-4 Incident Handling): FedRAMP Low Baseline · IR-4 · Incident Handling Control Statement: a. Implement an incident handling capability for incidents that is consistent with the incident response plan and includes preparation, detection and analysis, containment, eradication, and recovery; b. Coordinate incident handling activities with contingency planning activities; c. Incorporate lessons learned from ongoing incident handling activities into incident response procedures, training, and testing, and implement the re

Under the FedRAMP High baseline, IR-9 (IR-9 Information Spillage Response): FedRAMP High Baseline · IR-9 · Information Spillage Response Control Statement: Respond to information spills by: a. Assigning [organization-defined parameter] with responsibility for responding to information spills; b. Identifying the specific information involved in the system contamination; c. Alerting [organization-defined parameter] of the information spill using a method of communication not associated with the spill; d. Isolating the contaminated system or system component; e. Eradicati

NIST SP 800-171 Rev 3 control 03.06.04 (03.06.04 Incident Response Training) requires organizations to implement the following: Control Statement: SR-03.06.04.a Provide incident response training to system users consistent with assigned roles and responsibilities: SR-03.06.04.a.01 Within [organization-defined parameter] of assuming an incident response role or responsibility or acquiring system access, SR-03.06.04.a.02 When required by system changes, and SR-03.06.04.a.03 [organization-defined parameter] thereafter. SR-03.06.04.b Review and update incident response training content [organization-defined parameter] and following [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.06.04.

NIST SP 800-53 Rev 5 control IR-4.2 (Dynamic Reconfiguration) summarizes the requirements for this control: IR-4.2 · Dynamic Reconfiguration Control Statement: Include the following types of dynamic reconfiguration for [organization-defined parameter] as part of the incident response capability: [organization-defined parameter]. Supplemental Guidance: Include the following types of dynamic reconfiguration for [organization-defined parameter] as part of the incident response capability: [organization-defined parameter]. Dynamic reconfiguration includes changes to router rules, access control lists, i

NIST SP 800-171 Rev 3 control 03.06.01 (03.06.01 Incident Handling) is assessed by examining the following: Assessment Objectives: - an incident-handling capability that is consistent with the incident response plan is implemented. - the incident handling capability includes preparation. - the incident handling capability includes detection and analysis. - the incident handling capability includes containment. - the incident handling capability includes eradication. - the incident handling capability includes recovery.

NIST SP 800-53 Rev 5 control IR-3.2 (Coordination with Related Plans) summarizes the requirements for this control: IR-3.2 · Coordination with Related Plans Control Statement: Coordinate incident response testing with organizational elements responsible for related plans. Supplemental Guidance: Coordinate incident response testing with organizational elements responsible for related plans. Organizational plans related to incident response testing include business continuity plans, disaster recovery plans, continuity of operations plans, contingency plans, crisis communications plans, critical infrastructure

NIST SP 800-171 Rev 3 control 03.06.02 (03.06.02 Incident Monitoring, Reporting, and Response Assistance) is assessed by examining the following: Assessment Objectives: - system security incidents are tracked. - system security incidents are documented. - suspected incidents are reported to the organizational incident response capability within [organization-defined parameter]. - incident information is reported to [organization-defined parameter]. - an incident response support resource that offers advice and assistance to system users on handling and reporting incidents is provided.

NIST SP 800-53 Rev 5 control IR-5.1 (Automated Tracking, Data Collection, and Analysis) is assessed by examining, interviewing, and testing: IR-5.1 · Automated Tracking, Data Collection, and Analysis Control Statement: Track incidents and collect and analyze incident information using [organization-defined parameter]. Supplemental Guidance: Track incidents and collect and analyze incident information using [organization-defined parameter]. Automated mechanisms for tracking incidents and collecting and analyzing incident information include Computer Incident Response Centers or other electronic databases of incidents and network mon

NIST SP 800-53 Rev 5 control IR-7 (Incident Response Assistance) is assessed by examining, interviewing, and testing: IR-7 · Incident Response Assistance Control Statement: Provide an incident response support resource, integral to the organizational incident response capability, that offers advice and assistance to users of the system for the handling and reporting of incidents. Supplemental Guidance: Provide an incident response support resource, integral to the organizational incident response capability, that offers advice and assistance to users of the system for the handling and reporting of incidents.

IR-4.7 · Insider Threats · Intra-organization Coordination Control Statement: Coordinate an incident handling capability for insider threats that includes the following organizational entities [organization-defined parameter]. Supplemental Guidance: Coordinate an incident handling capability for insider threats that includes the following organizational entities [organization-defined parameter]. Incident handling for insider threat incidents (e.g., preparation, detection and analysis, containment, eradication, and recovery) requires coordination among many organizational entities, including mission or business owners, system owners, human resources offices, procurement offices, personnel offices, physical security offices, senior agency information security officer, operations personnel, risk executive (function), senior agency official for privacy, and legal counsel. In addition, organizations may require external support from federal, state, and local law enforcement agencies.

NIST SP 800-53 Rev 5 control IR-4.8 (Correlation with External Organizations) is assessed by examining, interviewing, and testing: IR-4.8 · Correlation with External Organizations Control Statement: Coordinate with [organization-defined parameter] to correlate and share [organization-defined parameter] to achieve a cross-organization perspective on incident awareness and more effective incident responses. Supplemental Guidance: Coordinate with [organization-defined parameter] to correlate and share [organization-defined parameter] to achieve a cross-organization perspective on incident awareness and more effective incident

From the NIST SP 800-172 Rev 3 Final Public Draft: ADVERSARY EFFECTS 1236 P reclude (Expunge), Impede (Contain, Exert), Limit (Shorten, Reduce), Expose (Scrutinize) REFERENCES Source Control: IR-04(11) 03.0 6.03E Behavior Analysis Analyze anomalous or suspected adversarial behavior in or related to [Assignment: organization-defined environments or resources]. DISCUSSION If the organization maintains a deception environment, an analysis of behaviors in that environment, including resources targeted by the adversary and the timing of the incident or event, can provide significant insights into adversarial tactics, techniques, and procedures. External to a deception environment, the analysis of anomalous behavior (e.g., changes in system performance or usage patterns) or suspected adversarial behavior (e.g., changes in searches

NIST SP 800-171 Rev 3 control 03.06.03 (03.06.03 Incident Response Testing) requires organizations to implement the following: 03.06.03 · Incident Response Testing Supplemental Guidance: Organizations test incident response capabilities to determine their effectiveness and identify potential weaknesses or deficiencies. Incident response testing includes the use of checklists, walk-through or tabletop exercises, and simulations. Incident response testing can include a determination of the effects of incident response on organizational operations, organizational assets, and individuals. Qualitative and quantitative data For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.06.03.

NIST SP 800-53 Rev 5 control IR-2.2 (Automated Training Environments) is defined as follows: IR-2.2 · Automated Training Environments Control Statement: Provide an incident response training environment using [organization-defined parameter]. Supplemental Guidance: Provide an incident response training environment using [organization-defined parameter]. Automated mechanisms can provide a more thorough and realistic incident response training environment. This can be accomplished, for example, by providing more complete coverage of incident response issues, selecting more realistic training scenarios and environments, and stressing the response capability.

NIST SP 800-53 Rev 5 control IR-8 (Incident Response Plan): IR-8 · Incident Response Plan Control Statement: a. Develop an incident response plan that: 1. Provides the organization with a roadmap for implementing its incident response capability; 2. Describes the structure and organization of the incident response capability; 3. Provides a high-level approach for how the incident response capability fits into the overall organization; 4. Meets the

NIST SP 800-53 Rev 5 control IR-6 (Incident Reporting) is assessed by examining, interviewing, and testing: IR-6 · Incident Reporting Control Statement: a. Require personnel to report suspected incidents to the organizational incident response capability within [organization-defined parameter] ; and b. Report incident information to [organization-defined parameter]. Supplemental Guidance: a. Require personnel to report suspected incidents to the organizational incident response capability within [organization-defined parameter] ; and b. Report incident information to [organization-defined parameter]

Under the FedRAMP Moderate baseline, IR-4 (IR-4 Incident Handling): FedRAMP Moderate Baseline · IR-4 · Incident Handling Control Statement: a. Implement an incident handling capability for incidents that is consistent with the incident response plan and includes preparation, detection and analysis, containment, eradication, and recovery; b. Coordinate incident handling activities with contingency planning activities; c. Incorporate lessons learned from ongoing incident handling activities into incident response procedures, training, and testing, and implement t

NIST SP 800-53 Rev 5 control IR-4 (Incident Handling) is assessed by examining, interviewing, and testing: IR-4 · Incident Handling Control Statement: a. Implement an incident handling capability for incidents that is consistent with the incident response plan and includes preparation, detection and analysis, containment, eradication, and recovery; b. Coordinate incident handling activities with contingency planning activities; c. Incorporate lessons learned from ongoing incident handling activities into incident response procedures, training, and testing, and implement the resulting changes accordi

NIST SP 800-53 Rev 5 control IR-4.15 (Public Relations and Reputation Repair) summarizes the requirements for this control: IR-4.15 · Public Relations and Reputation Repair Control Statement: (a) Manage public relations associated with an incident; and (b) Employ measures to repair the

reputation of the organization. Supplemental Guidance: (a) Manage public relations associated with an incident; and (b) Employ measures to repair the reputation of the organization. It is important for an organization to have a strategy in place for addressing incidents that have been brought to the attention of the general public, h

NIST SP 800-53 Rev 5 control IR-7.2 (Coordination with External Providers) summarizes the requirements for this control: IR-7.2 · Coordination with External Providers Control Statement: (a) Establish a direct, cooperative relationship between its incident response capability and external providers of system protection capability; and (b) Identify organizational incident response team members to the external providers. Supplemental Guidance: (a) Establish a direct, cooperative relationship between its incident response capability and external providers of system protection capability; and (b) Identify organizatio

Under the FedRAMP High baseline, IR-4.2 (IR-4.2 Dynamic Reconfiguration): FedRAMP High Baseline · IR-4.2 · Dynamic Reconfiguration Control Statement: Include the following types of dynamic reconfiguration for [organization-defined parameter] as part of the incident response capability: [organization-defined parameter]. Supplemental Guidance: Include the following types of dynamic reconfiguration for [organization-defined parameter] as part of the incident response capability: [organization-defined parameter]. Dynamic reconfiguration includes changes to router rules,

Under the FedRAMP High baseline, IR-2 (IR-2 Incident Response Training): FedRAMP High Baseline · IR-2 · Incident Response Training Control Statement: a. Provide incident response training to system users consistent with assigned roles and responsibilities: 1. Within [organization-defined parameter] of assuming an incident response role or responsibility or acquiring system access; 2. When required by system changes; and 3. [organization-defined parameter] thereafter; and b. Review and update incident response training content [organization-defined parameter]

Under the FedRAMP Moderate baseline, IR-6.1 (IR-6.1 Automated Reporting): FedRAMP Moderate Baseline · IR-6.1 · Automated Reporting Control Statement: Report incidents using [organization-defined parameter]. Supplemental Guidance: Report incidents using [organization-defined parameter]. The recipients of incident reports are specified in [IR-6b](#ir-6_smt.b) . Automated reporting mechanisms include email, posting on websites (with automatic updates), and automated incident response tools and programs. Assessment Objectives: Report incidents using [organization-defin

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: IR-03 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.06.03 [Assignment: organization-defined frequency] at least every 12 months Incident Response 3.6.4 Incident Response Training a. Provide incident response training to system users consistent with assigned roles and responsibilities: 1. Within [Assignment: organization-defined time period] (03.06.04.a.01) of assuming an incident response role or responsibility or acquiring system access, 2. When required by system changes, and 3. [Assignment: organization-defined frequency] (03.06.04.a.03) thereafter. b. Review and update incident response training content [Assignment: organization-defined frequency] (03.06.04.b.01) and following [Assignment: organization-defined events] (03.06.04.b.02). Relate

NIST SP 800-53 Rev 5 control IR-5 (Incident Monitoring) summarizes the requirements for this control: IR-5 · Incident Monitoring Control Statement: Track and document incidents. Supplemental Guidance: Track and document incidents. Documenting incidents includes maintaining records about each incident, the status of the incident, and other pertinent information necessary for forensics as well as evaluating incident details, trends, and handling. Incident information can be obtained from a variety of sources, including network monitoring, incident reports, incident response teams, user complaint

IR-4.12 · Malicious Code and Forensic Analysis Control Statement: Analyze malicious code and/or other residual artifacts remaining in the system after the incident. Supplemental Guidance: Analyze malicious code and/or other residual artifacts remaining in the system after the incident. When conducted carefully in an isolated environment, analysis of malicious code and other residual artifacts of a security incident or breach can give the organization insight into adversary tactics, techniques, and procedures. It can also indicate the identity or some defining characteristics of the adversary. In addition, malicious code analysis can help the organization develop responses to future incidents.

NIST SP 800-53 Rev 5 control IR-1 (Policy and Procedures) summarizes the requirements for this control: IR-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] incident response policy that: 2. Procedures to facilitate the implementation of the incident response policy and the associated incident response controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the incident response policy and procedures; and c. Review and upda